

Perimeter Security Configuration Guide

Prepared by: Omkar Sawant
Client: GlobalTech Corp
Date: 24 May 2026
Project: Implementing a Secure Network Architecture for a Large Enterprise
Organisation: Spinnaker Analytics

1. Purpose and Scope

- This guide documents the configuration of perimeter security controls for GlobalTech Corp's network. It covers the deployment and management of a next-generation firewall (NGFW) and an intrusion detection and prevention system (IDPS) at the HQ perimeter in Mumbai, with equivalent guidance for remote office perimeters in Delhi and Bangalore.
- The configurations in this guide directly remediate three findings from the Network Architecture Assessment Report (22 May 2026):
 - Finding 1: Legacy stateful firewall —> replaced with NGFW performing application-layer inspection
 - Finding 2: Overly permissive egress rules —> replaced with allowlist-based egress filtering
 - Finding 3: No IDPS deployed —> inline Suricata IDPS deployed with updated signature feeds

2. Lab Environment

The following tools were used to simulate and test the perimeter security configurations:

Component	Tool / Software	Purpose
NGFW (simulated)	pfSense 2.7 / OPNsense	Open-source firewall with app-layer filtering
IDPS	Suricata 7.x	Inline IPS with signature and anomaly detection
Network simulator	GNS3 / EVE-NG	Virtual network topology for isolated testing
Attack simulation	Metasploit Framework	Simulate port scans, exploits, C2 callbacks
Traffic analysis	Wireshark	Capture and inspect traffic pre/post rule application
Log review	Elastic SIEM (local)	Centralise and analyse firewall and IDPS logs

3. NGFW Configuration

3.1 Overview

- The NGFW replaces the legacy stateful firewall at the network perimeter.
- Unlike a stateful firewall, the NGFW inspects traffic at the application layer, identifies applications regardless of port, enforces application-specific policies, and decrypts TLS traffic to inspect for embedded threats.
- Recommended production solutions: Palo Alto Networks PA-Series, Fortinet FortiGate, or Cisco Firepower. In the lab, pfSense/OPNsense with the Suricata package is used for testing.

3.2 Interface Configuration

The NGFW is deployed with three logical interfaces:

Interface	Zone	Description
WAN (em0)	Untrusted / Internet	Upstream ISP — all inbound internet traffic
DMZ (em1)	Semi-trusted	Hosts web proxy, reverse proxy, email gateway
LAN (em2)	Trusted / Internal	Internal core switch — corporate network segments

3.3 Inbound Firewall Rules

Inbound rules control traffic arriving on the WAN interface. Default posture is deny-all; only explicitly permitted services are allowed:

Rule #	Traffic	Action
1	HTTPS (TCP 443) inbound to DMZ reverse proxy	PERMIT
2	SMTP (TCP 25) inbound to DMZ email gateway	PERMIT
3	IMAPS (TCP 993) inbound to DMZ email gateway	PERMIT
4	VPN IKEv2 (UDP 500, 4500) to VPN gateway	PERMIT
5	SSL VPN (TCP 443 on VPN interface) to VPN gateway	PERMIT
6	All other inbound traffic	DENY + LOG

3.4 Egress Firewall Rules

- Outbound rules replace the previous any-to-any egress policy with allowlist-based filtering.
- All web browsing from internal hosts must pass through the DMZ web proxy — direct internet access from workstations is blocked:

Rule #	Traffic	Action
1	HTTP/HTTPS from DMZ web proxy to internet	PERMIT
2	SMTP from DMZ email gateway to internet	PERMIT
3	DNS (UDP/TCP 53) from internal DNS server to approved resolvers only	PERMIT
4	NTP (UDP 123) from NTP server to trusted NTP pools	PERMIT
5	VPN tunnel traffic from VPN gateway to remote sites	PERMIT
6	Direct outbound HTTP/HTTPS from any internal host	DENY + LOG
7	All other outbound traffic not matched above	DENY + LOG

3.5 Application-Layer Inspection Rules

- The NGFW identifies and controls applications by behaviour, not just port number:
 - Block peer-to-peer (P2P) applications: BitTorrent, eMule — regardless of port used
 - Block anonymisation tools: Tor, VPN bypass apps, proxy avoidance tools
 - Block uncategorised HTTPS traffic that cannot be decrypted or identified
 - Allow standard business SaaS applications (Microsoft 365, Google Workspace, Zoom) to allowlisted domains only
 - Alert on unusual outbound data volumes to external destinations — potential data exfiltration

3.6 SSL/TLS Inspection

- The NGFW decrypts outbound TLS traffic for inspection, then re-encrypts before forwarding. This allows detection of threats hidden inside HTTPS:
 - Deploy an internal CA certificate to the NGFW for re-signing decrypted sessions
 - Push the internal CA certificate to all managed endpoints via group policy so browsers trust it
 - Exclude from decryption: banking sites, healthcare portals, and any site using certificate pinning
 - Log all decrypted sessions: source IP, destination, application identified, and verdict

3.7 NGFW Test Results

The following tests verified rule effectiveness in the lab:

Test	Method	Result
Direct internet access from workstation	Browse from LAN host without proxy configured	BLOCKED — egress rule 6 denied traffic
Proxy-routed browsing	Configure browser proxy, browse normally	PERMITTED — traffic exited via DMZ proxy
P2P application	Run BitTorrent client from LAN host	BLOCKED — app-layer rule identified and dropped
Tor/anonymiser	Attempt Tor Browser connection	BLOCKED — Tor exit node IPs and fingerprinting matched
Port scan from internet	Nmap -sS scan against WAN IP	BLOCKED + LOGGED — no open ports visible except permitted
TLS inspection	Browse to test site, check certificate in browser	Internal CA cert presented — traffic inspected successfully

4. IDPS Configuration (Suricata)

4.1 Overview

- Suricata is deployed in inline IPS mode on the NGFW WAN interface, inspecting all traffic before firewall rules are applied. In IPS mode, Suricata drops malicious packets in real time rather than only alerting.
 - Suricata uses three detection methods:
 - Signature-based: matches traffic against known attack patterns — CVEs, malware C2, exploit payloads
 - Protocol anomaly: flags traffic deviating from RFC specifications, e.g. malformed HTTP headers
 - Flow analysis: tracks connection state and flags unusual patterns such as excessive SYN packets or high-volume data transfers

4.2 Ruleset Configuration

The Emerging Threats Open ruleset is used as the base, supplemented with custom rules:

Rule Category	Source	Mode
Emerging Threats (ET) Open	Proofpoint ET Open — updated daily	IPS (block)
Malware C2 traffic	ET malware category	IPS (block)
Port scan detection	Custom threshold rules	IPS (block) + alert
DNS tunnelling	ET DNS category	IPS (block)
Web application attacks	ET web_server category	Alert only — tune before blocking
Custom GlobalTech rules	Locally defined	IPS (block)

4.3 Suricata Inline IPS Configuration

Core settings in suricata.yaml for inline IPS deployment:

```
# Set interface to inline IPS mode
af-packet:
  - interface: eth0
    copy-mode: ips
    copy-iface: eth1

# Enable rule files
rule-files:
  - /etc/suricata/rules/emerging-all.rules
  - /etc/suricata/rules/custom-globaltech.rules

# Default action order - drop takes priority
action-order:
  - drop
  - reject
  - alert
  - pass
```

4.4 Custom Rules

Custom Suricata rules for GlobalTech-specific threats:

```
# Block outbound traffic to known Tor exit nodes
drop ip $HOME_NET any -> $TOR_EXITS any (msg:"TOR exit node"; sid:9000001;
rev:1;)

# Alert on port scan - 15+ ports in 3 seconds from same source
alert tcp any any -> $HOME_NET any (msg:"Port scan"; flags:S;
  threshold:type threshold, track by_src, count 15, seconds 3; sid:9000002;
rev:1;)

# Block DNS to non-authorized resolvers
drop udp $HOME_NET any -> !$DNS_SERVERS 53 (msg:"Unauthorised DNS resolver";
sid:9000003; rev:1;)

# Alert on large outbound transfers - potential exfiltration
alert tcp $HOME_NET any -> $EXTERNAL_NET any (msg:"Large outbound transfer";
  dsize:>50000; sid:9000004; rev:1;)
```

4.5 Alert Tuning

The following tuning was applied after initial deployment to reduce false positives:

- Suppressed alerts for known internal vulnerability scanner IP range
- Whitelisted internal application servers triggering web_server rules due to unconventional headers
- Set threshold of 3 matches per source IP per minute before blocking — prevents single-packet false positives
- Weekly log review for first month; moved to monthly review after baseline established

4.6 IDPS Test Results

The following simulated attacks were used to verify IDPS effectiveness:

Attack Simulated	Tool Used	Result
Port scan (SYN scan)	Nmap -sS from external host	BLOCKED + ALERTED — rule 9000002 triggered
Exploit payload	Metasploit EternalBlue module	BLOCKED — ET exploit ruleset matched payload
Malware C2 beacon	Simulated C2 callback to known bad IP	BLOCKED — ET malware C2 rule triggered
DNS tunnelling	iodine DNS tunnel tool	BLOCKED — anomalous DNS query length detected
SQL injection in HTTP	sqlmap against test web app	ALERTED — web_server rules flagged injection patterns
ICMP flood	hping3 flood from external	BLOCKED — threshold rule triggered at 50 packets/sec

5. Log Forwarding to SIEM

All NGFW and IDPS logs are forwarded to the centralised Elastic SIEM at HQ:

- NGFW: syslog forwarding to SIEM collector on TCP 6514 with TLS encryption
- Suricata: eve.json output enabled; Filebeat agent ships logs to Elasticsearch
- Fields captured: timestamp, source IP, destination IP, port, protocol, action, rule ID, severity
- SIEM correlation rule: alert if same source IP triggers 5+ IDPS blocks within 10 minutes
- SIEM dashboard: real-time view of top blocked IPs, top triggered rules, and traffic volume by zone

6. Maintenance Schedule

Task	Frequency
Update Suricata rulesets (ET Open feed)	Daily — automated
Review IDPS alert logs and tune false positives	Weekly
Audit NGFW firewall rules — remove unused rules	Monthly
Review SSL/TLS inspection exclusion list	Monthly
Test NGFW and IDPS with simulated attacks	Quarterly
Update NGFW firmware and Suricata version	Within 30 days of patch release
Full perimeter security review	Annually

7. Summary

The following perimeter security controls are now operational for GlobalTech Corp:

- NGFW deployed — application-layer inspection, TLS decryption, and deny-all default posture
- Egress filtering enforced — allowlist-based outbound rules; all web traffic via DMZ proxy
- Suricata IDPS inline — blocks threats in real time using ET Open rulesets and custom GlobalTech rules
- All six attack simulations blocked or alerted as expected
- All logs forwarded to centralised SIEM with correlation rules and dashboards active